

Assessment 2: Secure Web Application Development

Task Overview

This assessment is designed to evaluate your understanding and practical skills in Information Security. You will be required to enhance the stall reservation platform developed as part of another module by identifying, mitigating, and addressing relevant OWASP Top 10 vulnerabilities.

Additionally, you will be required to implement user authentication and access control using either OIDC or SAML protocols with a cloud-based Identity Provider (IdP) of your choice.

Application Requirements

1. Your web application should allow Stall Vendors to reserve stalls at an exhibition venue. The application should include the following functionalities:
 - Display the profile information of the authenticated user, including:
Username, Name, Email Address, Contact Number, Organization/Business Name (if available)
 - Allow Stall Vendors to submit stall reservation requests, including:
 - i. Authenticated user's username (obtained from the authentication response returned by the IdP) – This can be used to identify reservations made by the particular vendor.
 - ii. Exhibition/Event Name (selected from a predefined list).
 - iii. Reservation Date (calendar selection, on or after the current date).
 - iv. Stall Type (e.g., Standard, Premium, Corner Stall).
 - v. Preferred Stall Size (e.g., Small, Medium, Large).
 - vi. Number of Stalls Required.
 - vii. Business Category (e.g., Food & Beverage, Clothing, Electronics, Handicrafts, Services).
 - viii. Special Requirements or Comments.
 - View all stall reservation requests made by the authenticated Stall Vendor.
 - Allow the Exhibition Organizer to view and manage all stall reservation requests submitted by Stall Vendors.
 - The application should support two user roles:
 - i. Stall Vendor – Can reserve stalls and view their own reservations.
 - ii. Exhibition Organizer – Owns and manages the exhibition venue, stalls, and vendor reservations.
2. Implement authentication and logout functionality using either OIDC or SAML protocols. You can use a cloud-based IDP of your choice, such as Asgardeo, Auth0, Okta, OneLogin, etc.
3. Ensure that your application is secure by avoiding any OWASP Top 10 vulnerabilities. Common vulnerabilities include, but are not limited to, SQL injection, XSS, CSRF, and authentication bypass. Test and mitigate these vulnerabilities during development.
4. Implement access control to the application's functionalities. Users should only be able to access and manage their own reservations. Access control should be based on the access token obtained from the IDP.

5. Technology Stack:

- Use any DB to store the records.
- Develop the web application using any technology and configure it to run with HTTPS.
- Ensure that any credentials and parameters that can be changed are configurable using configuration files such as application.properties or web.xml.

Grading Criteria

- The implementation of addressing the OWASP Top 10 vulnerability.
- Implementation of the below.
 - Login and logout flow using OIDC or SAML protocols.
 - Displaying user information of the authenticated user using the access token.
 - Validating and using access tokens to perform the functionalities of the application.
- The blog explains the above implementation.

Submission

1. Upload the source code to your private GitHub account and make the repository public. Please ensure that you remove any sensitive data, such as DB credentials, OIDC secrets, etc., and mention it in the readme for instructions on configuring the same. The readme should also provide instructions on deploying the web application and running it successfully. Also, please make sure to include the database creation script.
2. Write a blog on your experience, including security aspects considered, authentication protocols, implementation strategies, challenges faced, and the learning outcomes. Feel free to include a link to your GitHub repository within your blog for reference. You may use a public blog forum such as Medium to publish your blog.
3. Generate a JSON file with the details in the following format and name it using the format: SE2022XXX.json. Afterwards, please upload the file.

None

```
{
  "sid": "SE2022XXX",
  "name": "Name with Initials",
  "app-url": "localhost URL of the application",
  "git": "Public Git repository link",
  "blog": ["Public URL of the blog", "Public URL of the blog2 (Optional)"]
}
```

Good luck with your assessment! If you have any questions or need clarification, please don't hesitate to reach out.